Hemtentamen

Kurs: Nätverksteori Bas

Skola: Folkuniversitetet

Klass: SN25

Namn: Said Hamidovic

Datum: 22 september 2025

Fråga 1: Campusnät med segmentering och interna tjänster

1.1 Fysisk och logisk topologi

Fysisk Topologi

1. **Access-lagret: På Våningsplanen**

   På varje våningsplan ("Våning 1" och "Våning 2") finns ett centralt kopplingsskåp där all nätverksutrustning för våningen är placerad.

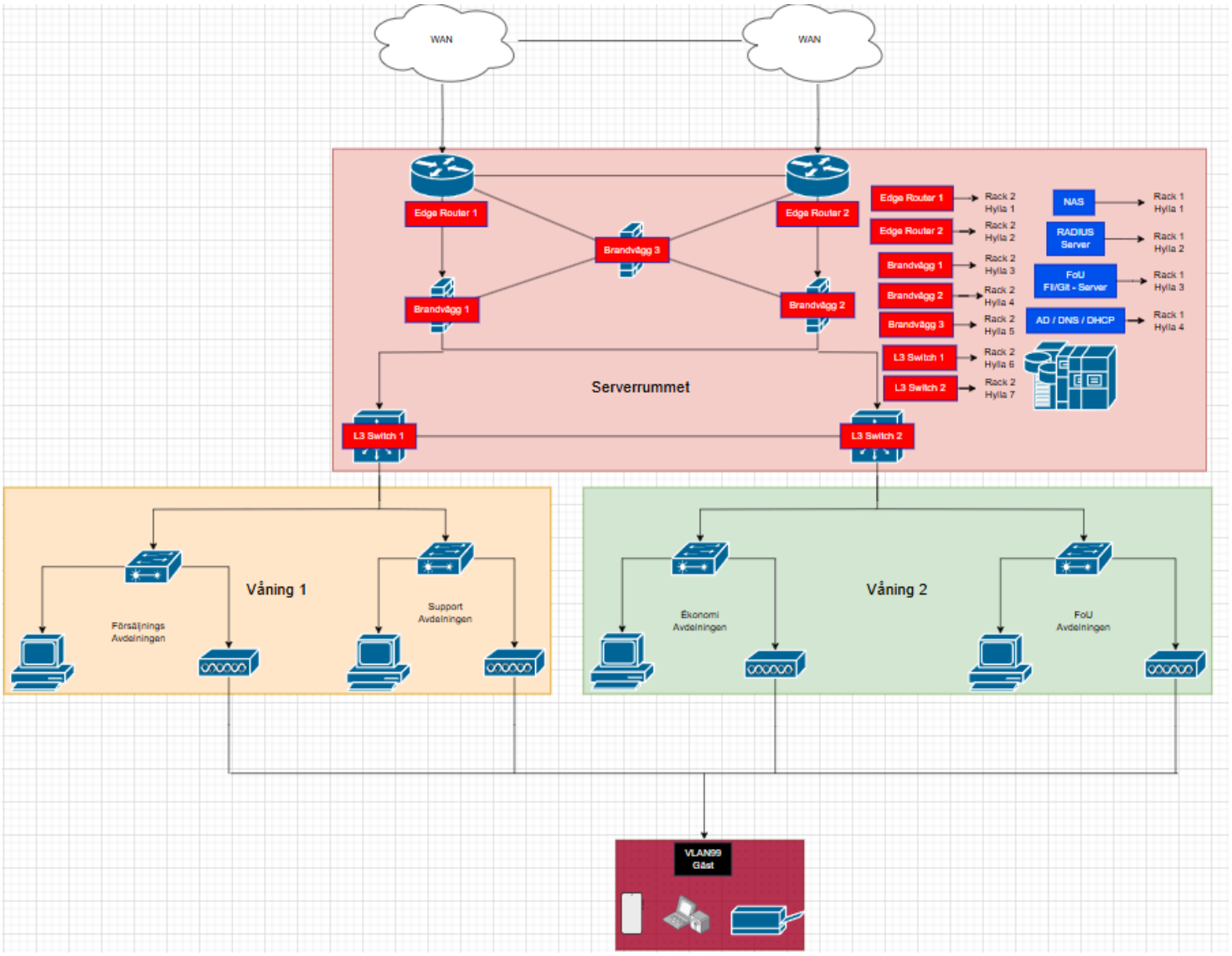
- **Användaranslutning:** Alla nätverksuttag från kontorsplatserna är anslutna via fast installerade kablar till detta skåp.
- **Access-switchar:** I skåpet finns L2 Access-switchar där användarnas datorer och de trådlösa accesspunkterna ansluts. Dessa switchar är utrustade med PoE+ (Power over Ethernet) för att kunna strömförsörja accesspunkterna direkt via nätverkskabeln.
- **Redundant anslutning:** Varje access-switch ansluts med två separata fiberkablar upp till serverrummet – en till varje redundant L3-switch. Detta garanterar att våningens nätverk inte slutar fungera om en kabel eller en central switch skulle fallera.

2. **Core/Distribution-lagret: I Serverrummet**

   Serverrummet är nätverkets hjärta och här placeras den centrala utrustningen.

- **Redundanta L3-switchar:** Två kraftfulla Layer 3-switchar utgör kärnan i nätverket. De hanterar all routing mellan olika VLAN och fungerar som den centrala kopplingspunkten för hela nätverket.

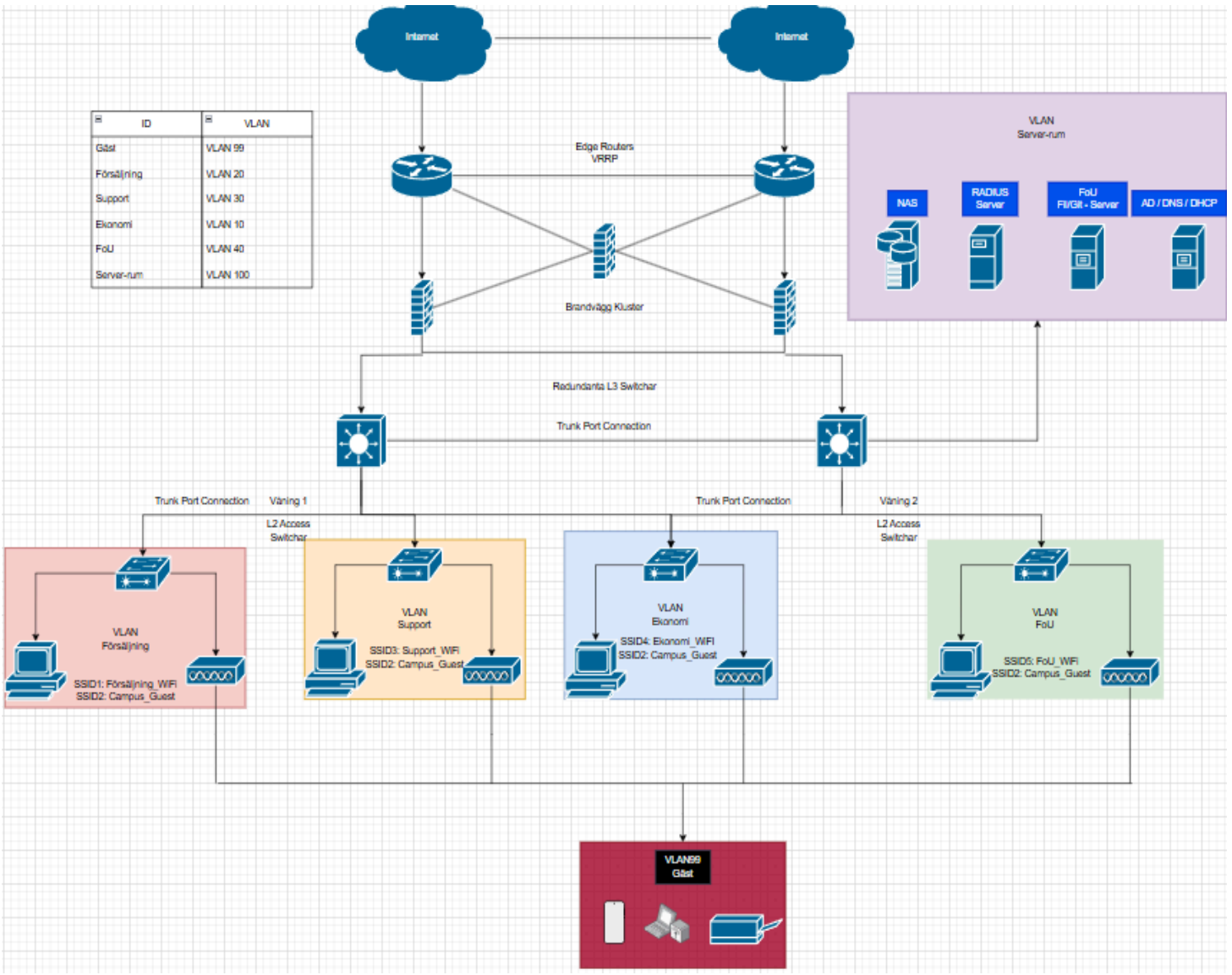
- **Serveranslutning:** Samtliga servrar (Filserver, AD, RADIUS etc.) är anslutna med redundanta länkar till båda L3-switcharna för att eliminera driftstopp vid fel på en switch.
- **Brandvägg och Edge-routrar:** Trafiken som ska ut till internet passerar genom ett redundant brandväggskluster och därefter via två Edge-routrar som är anslutna till olika internetleverantörer (ISP) för maximal tillgänglighet.



Logisk Topologi

Nätverket är logiskt uppdelat i VLAN (Virtual LAN) för att separera olika avdelningar och funktioner. Detta ökar säkerheten och förenklar administrationen.

- **VLAN 10:** Ekonomi
- **VLAN 20:** Försäljning
- **VLAN 30:** Support
- **VLAN 40:** FoU
- **VLAN 99:** Gästnätverk
- **VLAN 100:** Servrar



1.2 VLAN och Inter-VLAN Routing

För att enheter i olika VLAN ska kunna kommunicera med varandra används Inter-VLAN routing. Denna funktion hanteras av de redundanta L3-switcharna i serverrummet.

När en dator i exempelvis **VLAN 10 (Ekonomi)** behöver kommunicera med filservern i **VLAN 100 (Servrar)**, sker följande:

1. Datorn skickar trafiken till sin gateway, vilket är den virtuella IP-adressen (SVI) för VLAN 10 på L3-switchen.
2. L3-switchen tar emot trafiken, ser att destinationen är i ett annat subnät (VLAN 100) och routar paketet vidare till gränssnittet för VLAN 100.
3. Trafiken skickas därefter ut på den port där servern är ansluten.

All denna trafik mellan VLAN kan inspekteras och filtreras av accesslistor (ACL:er) på L3-switcharna eller, för ännu noggrannare kontroll, styras via det dedikerade brandväggs klustret.

1.3 Säkerhetszoner och Åtkomstmatris

För att strukturera säkerheten delas nätverket in i logiska säkerhetszoner. All trafik som passerar mellan dessa zoner inspekteras av brandväggen.

- **TRUST:** Internt nätverk för anställda (Ekonomi, Försäljning, Support, FoU). Här finns företagets kärnverksamhet och känslig information.
- **GUEST:** Isolerat nätverk för gäster med endast internetåtkomst.
- **SERVERS (DMZ):** En kontrollerad zon där interna servrar placeras. Åtkomst hit är strikt reglerad. (ACL samt Brandvägg)
- **UNTRUST:** Internet. All trafik härifrån anses opålitlig.

Åtkomstmatris

Käll zon –→ Destination Zon	Tjänst(hög nivå)	Riktning	Status	Syfte
TRUST → SERVERS	Filåtkomst (SMB), Git	Inkommande (till SERVERS)	Tillåtet	Tillåta anställda att nå den centrala fil- och Git-servern.
TRUST → UNTRUST	Webb (HTTP/HTTPS), DNS	Utgående	Tillåtet	Tillåta anställda att surfa på internet för arbetsrelaterade syften.
GUEST → UNTRUST	Webb (HTTP/HTTPS), DNS	Utgående	Tillåtet	Ge gäster strikt och isolerad internetåtkomst.
TRUST → SERVERS	DNS, DHCP	Inkommande (Till SERVERS)	Tillåtet	Låta klienter få IP-adress och göra interna namnuppslagningar.
GUEST → TRUST	Alla	Inkommande (Till TRUST)	Blockerat	Skydda det interna nätverket från gäster.
UNTRUST → SERVERS	Alla	Inkommande (Till SERVERS)	Blockerat	Skydda interna servrar från direkta anslutningsförsök från internet

1.4 Exponering av interna tjänster och Autentisering

För att säkerställa att endast behöriga användare får åtkomst till interna resurser används en centraliserad autentiserings- och auktorisationslösning.

- **Active Directory (AD):** En central AD-server hanterar samtliga användarkonton. När en anställd loggar in på sin dator verifieras användarnamn och lösenord mot AD. AD styr även behörigheter till resurser, som exempelvis vilka mappar en användare har tillgång till på filservern.
- **RADIUS-server:** För att säkra nätverksaccessen används en RADIUS-server. Både trådlös anslutning (via Wi-Fi) och trådbunden anslutning kan konfigureras med 802.1X-autentisering. Detta innebär att en användare eller enhet måste autentisera sig mot RADIUS-servern innan den tillåts ansluta till nätverket, vilket förhindrar att obehöriga enheter kopplas in.

1.5 Redundans, Driftbarhet och Failover

För att garantera hög tillgänglighet och minimera risken för avbrott har flera redundans åtgärder implementerats i designen.

- **Redundanta Länkar:** Varje access-switch är ansluten med dubbla länkar till de två centrala L3-switcharna. Protokoll som LACP (Link Aggregation Control Protocol) har använts för att slå ihop länkarna för ökad bandbredd och automatisk failover.
- **Redundanta Core-komponenter:** Nätverket har dubbla L3-switchar, ett brandväggskluster och dubbla Edge-routrar. Detta eliminerar "single points of failure" i nätverket.
- **Gateway-redundans (VRRP/HSRP):** För att säkerställa att klienterna alltid har en tillgänglig gateway används ett protokoll som VRRP (Virtual Router Redundancy Protocol). De två L3-switcharna delar på en virtuell IP-adress som agerar gateway. Om den primära switchen slutar fungera tar den sekundära omedelbart över trafiken utan avbrott för användarna.

- **Redundanta Internetanslutningar:** Genom att använda två olika internetleverantörer säkerställs kontinuerlig internetåtkomst även om en av leverantörernas tjänst ligger nere.

Test av Failover

För att verifiera att redundansen fungerar som avsett genomförs regelbundna och kontrollerade failover-tester.

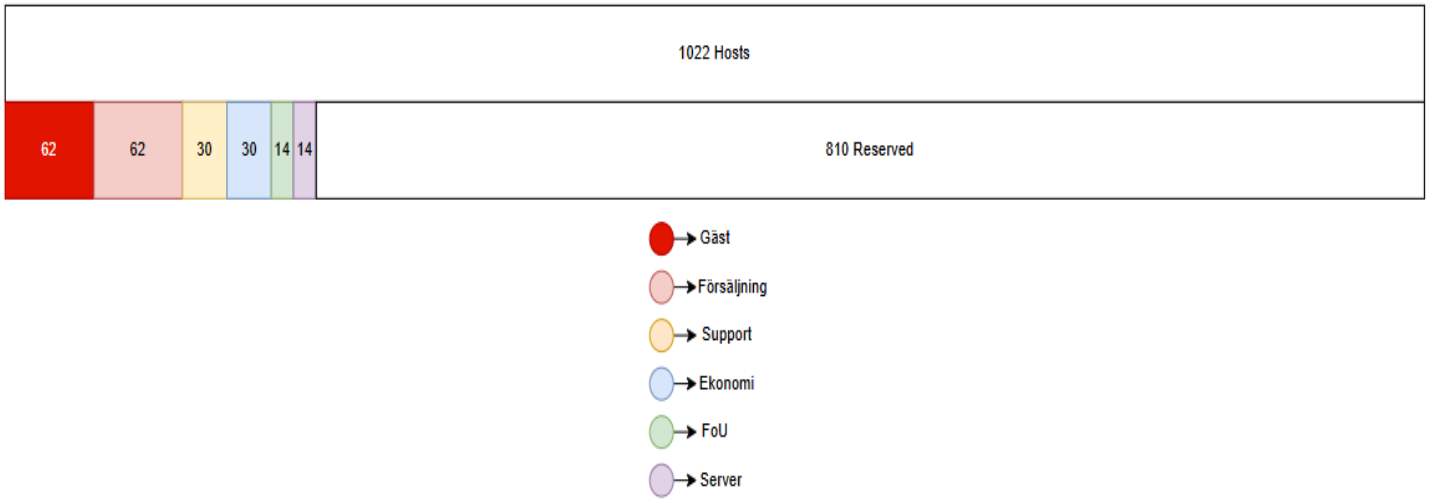
- **Länk-failover:** Ett test kan innebära att man fysiskt kopplar ur den primära länken från en access-switch och verifierar att trafiken omedelbart och utan märkbart avbrott omdirigeras via den sekundära länken.
- **Enhets-failover:** Ett annat test är att schemalagt starta om den primära L3-switchen eller brandväggen. Man övervakar då att den sekundära enheten tar över som aktiv enhet inom några sekunder, vilket kan valideras med en kontinuerlig ping från en klient till en server som inte visar mer än ett fåtal förlorade paket.

Fråga 2 – IPv4 VLSM, gateways och NAT (25 p)

2.1 VLSM, Tilldelning av subnät

VLAN / Nätverk	Värdbehov	Subnätmask	Nätadress	IP-intervall	Broadcast-adress	Gateway
Gästnät (VLAN 99)	50	/26 (255.255.255.192)	10.20.0.0	10.20.0.2 - 10.20.0.62	10-20.0.63	10.20.0.1
Försäljning (VLAN 20)	30	/26 (255.255.255.192)	10.20.0.64	10.20.0.66 - 10.20.0.126	10.20.0.127	10.20.0.65
Support (VLAN 30)	18	/27 (255.255.255.224)	10.20.0.128	10.20.0.130 - 10.20.0.158	10.20.0.159	10.20.0.129
Ekonomi (VLAN 10)	12	/27 (255.255.255.224)	10.20.0.160	10.20.0.162 - 10.20.0.190	10.20.0.191	10.20.0.161
Server (VLAN 100)	10	/28 (255.255.255.240)	10.20.0.192	10.20.0.194 - 10.20.0.206	10.20.0.207	10.20.0.193
FoU (VLAN 40)	8	/28 (255.255.255.240)	10.20.0.208	10.20.0.210 - 10.20.0.222	10.20.0.223	10.20.0.209

10.20.0.0/22



2.2 Route Aggregation

All trafik mellan VLAN skall skötas av de redundanta Layer (L3) switcharna.
För att skapa ett mer effektivt nätverk kommer **Route Aggregation** att tillämpas till den trafik som skall utanför det interna nätet.

L3 switcharna konfigureras att enbart annonsera (visa) en IP-Address uppåt mot brandväggsklustret, Routrarna och sedan ut mot internet. Detta gör nätverket mer effektivt, ger en ökad stabilitet samt möjliggör bättre administration.

Effektivitet: Genom denna tillämpning av route aggregation behöver brandväggsklustret samt edge-routrarna enbart spara en post (ip-adress) i sina routingtabeller istället för en post för varje enskilt VLAN. Detta minskar belastningen på brandväggarna och routrarna vilket resulterar i längre levnadstid och mindre latens för slutanvändarna.

Ökad stabilitet: Nätverkets stabilitet ökar genom att försäkra att den annonserade rutten ut mot internet håller ifall ett internt nät skulle börja få problem.

Administration: Brandväggsregler och policyhantering blir betydligt enklare då man kan adressera alla VLAN som ett större block (grupp) istället för varje enskilt VLAN. Möjligheten att adressera varje enskilt VLAN återstår om man behöver detta.

2.3 NAT/PAT strategi

Network Address Translation (NAT) behövs så att enheter i de olika VLANen skall kunna kommunicera med internet. Enheternas privata IP-adresser översätts till publika IP-adresser som internet kan förstå. NAT hanteras av brandväggen som är placerad på nätverkets edge.

Utgående trafik (från VLAN till internet)
För all trafik som initieras från det interna nätverket och går ut mot internet används Port Address Translation (PAT)

Vilka nät översätts?
Samtliga interna subnät som har ett behov av att nå internet omfattas av denna policy. Det inkluderar alla VLAN i TRUST-zonen och VLANet för GUEST-zonen.

Hur fungerar det?

Processen för **PAT** fungerar genom att brandväggen byter ut den enhetens privata käll-IP och port mot sin egen publika IP-adress och en unik, ledig port.

Denna översättning sparas temporärt i en translation table. När paketen kommer tillbaka från internet, använder brandväggen tabellen för att skicka paketen vidare till rätt enhet på korrekt VLAN.

Resultatet är att hundratals interna användare effektivt kan dela på en och samma publika IP-adress.

Inkommande trafik (från internet till internt)

Brandväggen tillämpar en **"deny by default"**-policy, vilket innebär att alla anslutningsförsök som initieras från internet (UNTRUST-zonen) blockeras som standard.

Undantaget från denna regel styrs av en process som kallas stateful inspection. Detta innebär att brandväggen aktivt övervakar och memorerar statusen för alla utgående anslutningar i en state table (tillståndstabell). När en intern användare inom ett VLAN ansluter till en extern tjänst (något på internet), skapar brandväggen en post i denna tabell. Endast inkommande trafik som är ett direkt och logiskt svar på en existerande anslutning i denna tabell tillåts passera.

All annan, oönskad trafik från internet som saknar en matchning i tillståndstabellen blockeras. Denna strategi är i linje med den definierade åtkomstmatrisen, där regeln UNTRUST → SERVERS är satt till Blockerat.

Fråga 3 – Systematisk felsökning och skydd enligt OSI

3.1 Felsökningssteg per OSI-lager

Felsökningen sker metodiskt lager för lager för att snabbt isolera källan.

Lager 1 – Fysiska lagret:
Anslutningen för servern och switchen verifieras genom att inspektera portarnas statuslampor (link status) och granska switchens loggar efter eventuell port flapping. En fysisk kontroll av kopplingsskåp genomförs för att upptäcka obehöriga enheter.

Lager 2 – Datalänklagret:
Målet är att spåra angriparens fysiska port. Käll-IP från serverns loggar mappas till en MAC-adress med kommandot “show arp” på L3-switchen. Därefter används “show mac address-table” för att identifiera exakt vilken switchport MAC-adressen är ansluten till.

Lager 3 – Nätverkslagret:
Nätverksåtkomst och regler verifieras med ping och traceroute mot källan. Samtidigt granskas ACL:er på L3-switcharna för att säkerställa att de fungerar som avsett.

Lager 4 – Transportlagret:
För att se vilka portar som används körs en skanning med “nmap” mot källan. Brandväggens loggar analyseras för att se detaljerad information om de TCP/UDP-sessioner som etablerats mot FoU-servern.

Lager 5 – Sessionslagret:
Här analyseras anslutningarnas livscykel med verktyg som “netstat” eller genom att granska brandväggens loggar. Man letar efter onormala mönster, där ett extremt högt antal snabbt öppnade och stängda sessioner från en käll-IP är en stark indikation på en automatiserad attack.

Lager 6 – Presentationslagret:
Felsökningen fokuserar på datakrypteringen. Med Wireshark inspekteras TLS-handskakningen mellan klienten och servern. Misslyckade handskakningar kan avslöja angriparens avsikter.

Lager 7 – Applikationslagret:
På detta lager sker den slutgiltiga analysen av själva attacken. Applikations- och AD-loggar granskas för att fastställa om det rör sig om en brute-force- eller password spraying-attack. Man identifierar vilka konton som är måltavlor och kan med Wireshark se de exakta kommandon som skickas.

3.2 Kompletterande skyddsåtgärder

För att härda nätverket implementeras följande skyddsåtgärder, strategiskt placerade på olika lager i OSI-modellen.

Skydd för Lager 1-2 (Fysisk/Datalänk): Port Security & ARP Inspection

Detta skydd härdar nätverkets grundläggande anslutningspunkt: porten på switchen. Port Security låser porten så att endast godkända enheter kan ansluta, medan Dynamic ARP Inspection (DAI) förhindrar identitetsstöld internt. Tillsammans stoppar dessa tekniker obehörig fysisk åtkomst och förhindrar MiTM (man-in-the-middle)-attacker.

Skydd för Lager 3-5 (Nätverk/Transport): Strikt åtkomstkontroll med ACLs

Genom att systematiskt härda Access Control Lists (ACLs) på L3-switcharna uppnås principen om "minsta möjliga privilegium". Genom att explicit blockera all onödig trafik mellan VLAN – exempelvis från Försäljning till FoU – begränsas en angripares möjlighet att röra sig i sidled (lateral movement) om en dator skulle bli kompromettterad.

Skydd för Lager 6-7 (Presentation/Applikation): Multifaktorautentisering (MFA)

Detta skydd säkrar själva applikationen. Genom att kräva en kod från till exempel Google Authenticator blir stulna lösenord värdelösa för en angripare. MFA är ett extremt effektivt skydd som bryter attackkedjan vid det mest kritiska steget: själva autentiseringen.

Fråga 4 – Prestanda: hastighet, latens, jitter, förlust & QoS

4.1 Grundläggande begrepp för Nätverksprestanda

Bandbredd

- Teoretisk maximal kapacitet för en nätverkslänk. Man kan tänka sig en motorväg som bandbredd, antalet filer på vägen bestämmer hur många bilar (paket) kan ta sig fram samtidigt. Mäts i bitar per sekund (bps), (Mbps), (Gbps).

- **Throughput** är den faktiska, uppmätta hastigheten som en länk överför data. Den är ofta lägre på grund av andra faktorer i ett nätverk som nätverksbelastning, protokoll-overhead som är nödvändig för att hantera datakommunikation samt latens.

Påverkan av nätverkstjänster

- Videostreaming, stora filöverföringar samt molntjänster kräver hög throughput.

- Om dessa tjänster inte har tillgång till hög throughput kommer nedladdningarna vara långsamma, videos kommer att buffra och slutanvändaren kommer att klaga på att allt går segt och långsamt.

Latens/Latency

- Latens är tiden det tar för ett paket att färdas från källa till destination. Det mäts som "Round Trip Time" (RTT) och anges i millisekunder (ms). Detta kan förklaras som tiden bilen tar att åka från punkt A till punkt B på tidigare nämn motorväg.

Påverkan på tjänster

- Realtidstjänster såsom onlinespel är omedelbart kritiska. För hög latens i onlinespel kallas "Lagg". Videomöten och fjärrstyrning är också känsliga för hög latens.
- Nätverk med hög bandbredd fast med hög latens kan kännas långsamt för slutanvändarna.

Jitter

- Jitter är variationen i latens över tid. Det är ett mått på hur ojämn ankomsttiden är på paketen. Om latensen konstant är till exempel "15 ms" så är jitter lågt. Om latensen hoppar mellan olika latens-värden, till exempel “15-125” ms så är jitter hög. I motorvägs exemplet så är jitter att bilarna anländer i oregelbundna mellanrum istället för i bra takt.

- Mediastreaming och VoIP-samtal är tjänster som är känsliga för jitter. För hög jitter i dessa tjänster resulterar i hackigt eller förvrängt ljud/bild. Vanlig filöverföring påverkas inte märkbart av hög jitter.

Paketförlust (Packet Loss)

- När ett eller flera paket som skickas över ett nätverk inte når sin destination kallas det för Packet loss. Detta orsakas av nätverksbelastning, hårdvarufel eller störningar på en trådlös länk. Packet loss mäts i procent av totalt skickade paket.

- TCP-baserade tjänster som hemsidor eller filöverföring är skyddade då TCP protokollet är designat för Packet loss genom att begära en omsändning av förlorade paket. Omsändning av paket resulterar i kraftigt reducerad throughput.

- UDP-baserade tjänster som onlinespel är inte skyddade då UDP protokollet inte skickar om förlorade paket vilket resulterar till permanent dataförlust. Slutanvändaren upplever detta som korta avbrott.

4.2 Jämförelse av tjänster

Realtidstjänster som VoIP/videomöten och, Dataöverföringstjänster som filöverföring/backup har olika krav på nätverket.

VoIP/videomöten

- **Känslighet:** Tjänsterna är extremt känsliga för jitter och latens.

Problemhantering

- **Buffer (Jitter buffert):**
  Om jitter är för högt kan ljudet bli hackigt och bilden fryser. För att motverka detta kan applikationen lagra datapaket i en "buffert" för att sedan spela ut dem i jämn takt.
  - **Exempel:** Ett videomöte över ett instabilt Wi-Fi resulterar i att datapaketen anländer i ojämn takt. **Bufferten** samlar upp de ojämnt ankommande paketen och spelar sedan upp dem som en jämn och kontinuerlig ström. Detta är anledningen till att ett samtal kan flyta på bra trots att nätverket undertill är instabilt. När bufferten töms på grund av för stora fördröjningar är det då ljudet blir robotaktigt eller bilden fryser till.

- **Adaptive Codecs:**
  Om applikationen märker av ett sämre nätverk förhållande så kan den byta till en codec som kräver mindre bandbredd. Detta resulterar i sämre ljud/bildkvalité men behåller anslutningen.
  - **Exempel:** Om applikationen känner av ett försämrat nätverks förhållande så byter den automatiskt till en mindre krävande codec. Du märker detta genom att din videobild blir mer pixlig och lågupplöst, men ljudet och anslutningen förblir stabil. Den adaptiva codecen offrar alltså bildkvalitet för att säkerställa att samtalet kan fortsätta.

- **Packet Loss:**
  Eftersom UDP inte skickar om förlorade paket så leder packet loss till glapp i ljud och bild.
    - **Exempel:** Om det blir tyst i en tiondels sekund och man missar ord utav varandra under ett VoIP-samtal så var det datapaketet som innehöll den information som precis förlorades. Detta eftersom samtalet använder UDP och om ett paket förloras så kommer det att försvinna.

Filöverföring/Backup

- **Känslighet:** Tjänsterna är primärt känsliga för throughput och packet loss. Jitter och latens har en mycket mindre påverkan, då målet är att överföra stora datamängder så snabbt och tillförlitligt som möjligt.

Problemhantering

- **TCP Window Size:** Filöverföringar använder TCP-protokollet som optimerar hastigheten genom att definiera hur mycket data som kan skickas innan en bekräftelse (ACK) krävs från mottagaren. En större "fönsterstorlek" kan öka throughput, speciellt på nätverk med hög latens, eftersom sändaren inte behöver vänta lika ofta på en ACK.
    - Exempel: Vid hög latens (t.ex. 175 ms) är TCP Window Size kritisk för hastigheten för nedladdning eller överföring.
        - Liten Window Size (t.ex. 64 KB) Servern kan bara skicka en liten mängd data för att sedan vänta 175 ms för en ACK innan den kan skicka mer. Detta resulterar i en längre nedladdning/överföringstid.
        - Stor Window Size (t.ex. 1MB) Nu kan servern skicka en större mängd data utan att behöva vänta 175 ms på en ACK vilket resulterar i en betydligt snabbare nedladdning/överföringstid.

- **Omförsök (Retransmissions):** TCP garanterar att all data kommer fram. Om ett paket förloras (packet loss), begär TCP en omsändning av det förlorade paketet. Detta säkerställer en felfri överföring men leder till att den totala throughputen minskar kraftigt.
    - TCP-protokollet garanterar att all data kommer fram till destinationen även om packet loss inträffar.
        - Om en server skickar 4 paket till en dator men det tredje paketet försvinner så kommer detta att ske.
            - Datorn tar emot paket 1, 2 och bekräftar dem genom att skicka en ACK 2
            - När sedan paket 4 anländer med det tredje paketet saknas så kommer datorn fortsätta skicka ACK 2 till servern för att visa att den inte har tagit emot tredje paketet.
            - Servern kommer då endast skicka ut det förlorade tredje paketet.

4.3 Mät- och förbättringsåtgärder

För att optimera nätverket för olika applikationer används en systematisk process: definiera krav, implementera en åtgärd och validera resultatet med mätningar.

Förbättra prestanda för VoIP/Videomöten (Realtid)

Krav: Låg latens, lågt jitter och minimal paketförlust.

Åtgärd: Implementera DSCP-baserad QoS genom att märka realtidstrafik med Expedited Forwarding (EF) och placera den i en prioritetskö på switchar och routrar. Detta säkerställer att den prioriteras över annan mindre viktigare trafik.

Validering: iperf3 vilket är ett verktyg för att mäta hastighet och andra parametrar för TCP, UDP och SCTP protokoll. Med iperf3 mäts jitter och paketförlust för simulerad VoIP-trafik, både före och efter QoS-aktivering, samtidigt som nätverket belastas med en stor filöverföring. Åtgärden är lyckad om jitter och paketförlust förblir låga även under belastning.

Förbättra prestanda för Filöverföring/Backup (Dataöverföring)

Krav: Maximal throughput.

Åtgärd: Förhindra paketfragmentering genom MTU(Maximum Transmission Unit)/MSS(Maximum Segment Size)-justering. Detta görs effektivt via MSS Clamping på brandväggen, vilket automatiskt anpassar paketens storlek för att optimera TCP-överföringar.

Validering: Med iperf3 mäts maximal TCP-throughput före och efter justeringen. Parallellt används NetFlow(Protokoll som samlar metadata om nätverkstrafiken) för att passivt övervaka nätverket. Åtgärden är lyckad om iperf3 visar en signifikant högre throughput och NetFlow visar en minskning av fragmenterade paket.

Fråga 5 – Protokoll i praktiken

Protokoll 1: DHCP (Dynamic Host Configuration Protocol)

Protokollet DHCP är en viktig tjänst i moderna nätverk vars primära funktion är att automatiskt tilldela IP-adresser och andra nätverksinställningar som gateway och DNS-server. Det används i praktiskt taget alla nätverk, från våra mindre hemmanätverk till stora företag, för att undvika tidskrävande manuell IP-konfiguration.

DHCP är ett protokoll på Applikationslagret i TCP/IP-modellen och lager 7 i OSI-modellen. DHCP använder UDP för sin kommunikation och IP-tilldelningen sker genom en process i fyra steg kallad DORA:

1. Discover: En ny klient skickar ut en broadcast-förfrågan för att hitta en server.
2. Offer: Servern svarar med ett erbjudande om en ledig IP-adress.
3. Request: Klienten accepterar formellt erbjudandet.
4. Acknowledge: Servern bekräftar och slutför tilldelningen.

Ett vardagligt exempel är när en gäst ansluter till företagets gäst-WiFi och omedelbart får en fungerande nätverksanslutning. Trots sin stora nytta medför DHCP en betydande säkerhetsrisk i form av "Rogue DHCP Servers". En angripare kan starta en egen DHCP-server för att dela ut felaktiga nätverksinställningar och på så sätt genomföra en "man-in-the-middle"-attack. För att motverka detta hot är det “best practice” att aktivera DHCP Snooping på nätverkets switchar, en funktion som effektivt blockerar otillförlitliga DHCP-erbjudanden.

Protokoll 2: TLS (Transport Layer Security)

Protokollet TLS är den grundläggande tekniken bakom HTTPS vars syfte är att skapa en säker kommunikationskanal. Detta uppnås genom att garantera sekretess (kryptering), integritet (skydd mot manipulering) och autentisering (verifiering av serverns identitet med digitala certifikat).

TLS verkar mellan Applikations- och Transportlagret i TCP/IP-modellen och förlitar sig på TCP. I OSI-modellen tillhandahåller det viktiga funktioner för Lager 5 (Session) och Lager 6 (Presentation). Innan någon data skickas, genomförs en TLS Handshake. Under denna process validerar klienten serverns certifikat, och parterna kommer överens om TLS-version,Cipher Suites (krypteringssvit) och förhandlar säkert fram en gemensam, symmetrisk sessionsnyckel som sedan används för att kryptera all data.

Ett vardagligt exempel är vid inloggning på en internetbank, där TLS både säkerställer att man är ansluten till bankens äkta server och krypterar inloggningsuppgifterna. De största säkerhetsriskerna är användningen av föråldrade TLS-versioner och svaga cipher suites, vilket kan göra trafiken sårbar. Den bästa praxis är därför att servrar konfigureras att endast tillåta moderna protokoll som TLS 1.2/1.3, använda starka cipher suites som till exempel TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384, TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 och ha en automatiserad process för att förnya certifikat.